GUIDE DE RÉFÉRENCE

Cybersécurité

Sécuriser, détecter, réagir

Systèmes d'information d'entreprise et serveurs personnels

Synthèse opérationnelle des recommandations publiques de l'ANSSI, du CERT-FR, de la CNIL, de Cybermalveillance.gouv.fr et des autorités francophones (Belgique, Suisse, Canada), complétée de bonnes pratiques de terrain.

EN CAS D'ATTAQUE EN COURS

Aller directement à la Carte réflexe (page 3) et à la Partie 5.
CERT-FR 24h/24 : 3218 ou 09 70 83 32 18 • cybermalveillance.gouv.fr/17cyber

Version 1.0 — octobre 2026 • TLP:CLEAR — diffusion libre

Conserver une copie hors ligne et une copie papier

Mode d'emploi de ce guide

Ce document rassemble, dans un format unique et utilisable hors connexion, l'essentiel des recommandations publiques des autorités de cybersécurité francophones : ANSSI et CERT-FR, CNIL, Cybermalveillance.gouv.fr, Centre pour la Cybersécurité Belgique (CCB), Office fédéral de la cybersécurité suisse (OFCS) et Centre canadien pour la cybersécurité. Il les complète de pratiques de terrain éprouvées. Il s'adresse aux responsables informatiques, administrateurs et RSSI de petites et moyennes structures, ainsi qu'aux particuliers qui exploitent leurs propres serveurs.

Vous êtes…	Commencez par	Puis
En pleine attaque	Carte réflexe (page suivante)	Partie 5 — Réagir à une compromission
Responsable d'un SI d'entreprise	Partie 1 — Fondamentaux et mesures prioritaires	Partie 2 — Durcissement technique, puis Partie 6 — Plan de préparation
Administrateur de serveurs	Partie 2 (Linux, Windows, réseau, journalisation)	Partie 5, fiches de vérification Linux et Windows
Particulier / homelab	Partie 4 — Sécuriser chez soi	Partie 2 — chapitre Linux et sauvegardes
Dirigeant	Mesures prioritaires (Partie 1)	Gestion de crise et obligations (Partie 5)

Comment garder ce guide toujours sur soi

Un guide de réponse à incident ne sert à rien s'il est stocké sur le système qui vient d'être chiffré. Appliquez ces quatre règles dès aujourd'hui :

1. **Sur le téléphone** : enregistrez le PDF dans l'application Fichiers (iPhone) ou Téléchargements/Drive « disponible hors connexion » (Android). Vérifiez qu'il s'ouvre en mode avion.
2. **Sur papier** : imprimez au minimum la Carte réflexe, les fiches de la Partie 5 et l'annexe Contacts (remplie). Rangez un exemplaire au bureau et un autre chez vous.
3. **Sur une clé USB** dédiée, rangée avec les supports de sauvegarde hors ligne.
4. **Hors du SI** : une copie dans un espace en ligne personnel, distinct des comptes de l'entreprise (une messagerie ou un cloud d'entreprise compromis peuvent être inaccessibles ou surveillés par l'attaquant).

Conventions utilisées

Les cases ☐ sont des listes de contrôle à cocher sur la version imprimée. Les encadrés sombres contiennent des commandes ou extraits de configuration : ce sont des exemples à adapter et à tester avant tout déploiement en production. Les encadrés bleus renvoient au guide officiel de référence. Les liens sont cliquables ; le sommaire et les signets du PDF permettent de naviguer rapidement.

Avertissement

Ce guide est une synthèse indépendante de documents publics. Il ne remplace ni les documents officiels cités (qui font foi et évoluent), ni l'intervention d'un prestataire qualifié en cas d'incident grave, ni un conseil juridique. Vérifiez périodiquement les mises à jour des guides sources (Annexe A).

Carte réflexe — attaque en cours

Restez calme, tracez tout, ne détruisez rien. Une mauvaise réaction aggrave souvent plus que l'attaque elle-même.

À FAIRE, DANS CET ORDRE

1. **Ouvrir une main courante** (papier ou hors SI) : heure, auteur, action, machines. Dès la première minute.
2. **Isoler du réseau** les machines suspectes (câble, Wi-Fi, port du commutateur, quarantaine EDR) **sans les éteindre** : la mémoire vive contient des preuves.
3. **Rançongiciel actif** : couper les flux Internet et les liaisons entre sites ; protéger et déconnecter les sauvegardes ; isoler les hyperviseurs.
4. **Communiquer hors bande** : téléphone, messagerie hors SI. Considérer la messagerie et l'annuaire comme lus par l'attaquant.
5. **Ne pas se connecter** en RDP/SSH avec un compte d'administration du domaine sur une machine suspecte.
6. **Qualifier** : quoi, où, depuis quand, quel périmètre, quels impacts métiers (fiche 5.2).
7. **Alerter** : direction, prestataire de réponse à incident, assureur, CERT/CSIRT compétent.
8. **Préserver les traces** : journaux, copies mémoire et disque avant toute réinstallation.
9. **Déclarer** : plainte, CNIL sous 72 h si données personnelles, autorités sectorielles.

À NE PAS FAIRE

- ✕ Payer la rançon (aucune garantie, finance le crime, peut être illégal selon le destinataire).
- ✕ Éteindre brutalement ou réinstaller « pour repartir vite » avant d'avoir compris le point d'entrée.
- ✕ Brancher les sauvegardes sur le réseau compromis pour « vérifier ».
- ✕ Changer tous les mots de passe depuis un poste compromis (l'attaquant les capturerait).
- ✕ Lancer des outils de nettoyage au hasard qui effacent les traces.
- ✕ Prévenir l'attaquant (messages internes visibles, comptes désactivés dans le désordre).

Votre premier appel

Votre prestataire de réponse à incident ou, à défaut, le CSIRT régional (PME, collectivités, associations) ou Cybermalveillance.gouv.fr / 17Cyber. Le CERT-FR (3218) pour les administrations et opérateurs régulés. Puis l'assureur. Les contacts sont page suivante.

Carte réflexe — contacts et déclarations

Qui	Contact	Pour qui / pourquoi
CERT-FR (ANSSI)	**3218** ou **09 70 83 32 18** (24h/24, 7j/7) +33 9 70 83 32 18 depuis l'étranger cert-fr@ssi.gouv.fr	Administrations, opérateurs d'importance vitale et de services essentiels ; peut orienter toute organisation.
Cybermalveillance.gouv.fr / 17Cyber	cybermalveillance.gouv.fr/17cyber	Particuliers, TPE/PME, collectivités : diagnostic en ligne et mise en relation avec des prestataires labellisés.
CSIRT régional	cert.ssi.gouv.fr/csirt/csirt-regionaux	Collectivités, PME, ETI, associations : premier niveau de réponse gratuit.
CNIL	cnil.fr, rubrique « Notifier une violation de données personnelles »	Notification d'une violation de données personnelles sous 72 h.
Police / gendarmerie	17 en cas d'urgence ; plainte au commissariat ou à la gendarmerie	Dépôt de plainte : déclenche l'enquête et documente votre bonne foi.
Belgique	CCB : ccb.belgium.be (incident)	Organisations belges.
Suisse	OFCS : ncsc.admin.ch (annonce)	Organisations suisses.
Canada	Centre canadien pour la cybersécurité : cyber.gc.ca	Organisations canadiennes.

Déclarations : qui, quand

Déclaration	Délai	Condition
Main courante et registre interne	Immédiat	Toujours.
Assureur cyber	Au plus vite	Selon contrat ; il peut mandater un prestataire.
Plainte	≤ 72 h	Condition de l'indemnisation par l'assurance des pertes liées à une cyberattaque (France).
CNIL	≤ 72 h	Si des données personnelles sont concernées (notification initiale possible, à compléter).
Personnes concernées	Sans délai injustifié	Si le risque pour elles est élevé.
Autorité NIS 2 (ANSSI en France)	24 h / 72 h / 1 mois	Entités essentielles ou importantes : alerte précoce, notification, rapport final.
Autorités sectorielles	Variable	Santé, finance, énergie, etc. : voir le juridique.

Complétez l'annexe B (contacts internes, prestataire, assureur, hébergeur, opérateur télécom) et imprimez-la avec cette carte. En crise, l'annuaire de l'entreprise est souvent inaccessible.

Sommaire

Mode d'emploi de ce guide . . . 2
Carte réflexe — attaque en cours . . . 3
Carte réflexe — contacts et déclarations . . . 4

Partie 1 — Fondamentaux et mesures prioritaires 7

1.1 Comprendre la menace actuelle . . . 8
1.2 Gouvernance : les bases organisationnelles . . . 8
1.3 Les 5 mesures préventives prioritaires de l'ANSSI . . . 9
1.4 Socle d'hygiène : les 42 mesures en un coup d'œil . . . 9
1.5 Feuille de route en trois vagues . . . 10

Partie 2 — Durcissement technique 11

2.1 Identités, authentification et privilèges . . . 12
2.2 Active Directory : protéger le cœur du SI . . . 13
2.3 Postes de travail Windows . . . 14
2.4 Serveurs Linux (entreprise et personnel) . . . 14
2.5 Serveurs Windows . . . 17
2.6 Réseau, cloisonnement et accès distants . . . 18
2.7 Messagerie et suites collaboratives (M365, Google Workspace) . . . 19
2.8 Sites web, applications et services exposés . . . 19
2.9 Virtualisation, conteneurs et cloud . . . 20
2.10 Journalisation, supervision et détection . . . 21
2.11 Sauvegardes et capacité de reprise . . . 22
2.12 Gestion des vulnérabilités et des correctifs . . . 22
2.13 Facteur humain, prestataires et nomadisme . . . 23

Partie 3 — Données personnelles et obligations 24

3.1 RGPD : l'obligation de sécurité . . . 25
3.2 Violation de données : que faire ? . . . 25
3.3 Plainte, assurance et NIS 2 . . . 25

Partie 4 — Sécuriser chez soi 26

4.1 Les comptes : la priorité absolue . . . 27
4.2 Box, Wi-Fi et réseau domestique . . . 27
4.3 Appareils . . . 27
4.4 NAS, homelab et serveurs auto-hébergés . . . 27

4.5 Sauvegardes personnelles 28
4.6 Particulier victime : premiers réflexes 28

Partie 5 — Réagir à une compromission 29

5.1 Organisation et principes de la réponse 30
5.2 Qualifier l'incident 30
5.3 Endiguer : contenir l'attaque 31
5.4 Cas particulier : chiffrement ou effacement en cours 32
5.5 Préserver les preuves 32
5.6 Investiguer : comprendre avant de reconstruire 33
5.7 Fiche de vérification : serveur Linux suspect 34
5.8 Fiche de vérification : machine Windows suspecte 35
5.9 Remédier : la méthode E3R de l'ANSSI 35
5.10 Reconstruire et reprendre l'activité 36
5.11 Gestion de crise et communication 37
5.12 Scénarios fréquents : conduites à tenir 37
5.13 Après l'incident : retour d'expérience 38

Partie 6 — Plan de préparation 39

6.1 Calendrier des routines de sécurité 40
6.2 Auto-évaluation rapide 40
6.3 Idée d'exercice sur table (2 heures) 41

Annexes 42

Annexe A — Bibliothèque de référence (liens directs) 43
Annexe B — Contacts d'urgence (à remplir et imprimer) 46
Annexe C — Main courante d'incident (modèle) 47
Annexe D — Modèles de messages de crise 48
Annexe E — Glossaire 48

PARTIE 1

Fondamentaux et mesures prioritaires

Avant toute technique : savoir ce que l'on protège, qui en est responsable, et appliquer en premier les quelques mesures qui évitent la majorité des attaques constatées par l'ANSSI. Selon l'agence, la plupart des attaques sur lesquelles elle est intervenue auraient pu être évitées par l'application des mesures d'hygiène informatique.

1.1 Comprendre la menace actuelle

Les attaques qui touchent le plus les entreprises, collectivités et particuliers suivent des schémas répétitifs. Les comprendre permet de prioriser les défenses.

Menace	Mode opératoire typique	Défenses les plus efficaces
Rançongiciel avec double extorsion	Intrusion via VPN/RDP/pare-feu vulnérable, identifiants volés ou hameçonnage ; latéralisation ; prise de l'Active Directory ; destruction des sauvegardes ; vol puis chiffrement, souvent la nuit ou le week-end.	Correctifs des équipements exposés, MFA, cloisonnement de l'administration, sauvegardes hors ligne, supervision, EDR.
Compromission de messagerie (BEC)	Vol d'identifiants (hameçonnage, AiTM), règles de transfert cachées, fraude au virement / au président.	MFA résistant à l'hameçonnage, alertes sur règles de boîte, procédure de double validation des virements.
Exploitation de vulnérabilités exposées	Scan massif d'Internet dans les heures suivant la publication d'une faille (VPN, pare-feu, serveurs web, CMS).	Inventaire des services exposés, veille CERT-FR, correction prioritaire des failles activement exploitées.
Vol de données / fuite	Accès à des partages, bases ou stockages cloud mal configurés ; exfiltration.	Moindre privilège, chiffrement, journalisation des accès, revue des droits.
Attaque par la chaîne d'approvisionnement	Compromission d'un prestataire/infogérant ou d'un logiciel tiers disposant d'accès.	Accès prestataires cloisonnés, tracés et limités dans le temps ; clauses de sécurité.
Déni de service (DDoS)	Saturation des services en ligne, parfois couplée à l'extorsion.	Protection anti-DDoS de l'hébergeur/opérateur, architecture résiliente.

1.2 Gouvernance : les bases organisationnelles

- **Un responsable désigné** de la sécurité (RSSI ou référent), avec du temps et un accès direct à la direction. Dans une petite structure, ce peut être le responsable informatique.
- **Une cartographie du SI** tenue à jour : matériels, logiciels et versions, comptes, flux, interconnexions, prestataires, services exposés sur Internet. On ne protège pas ce que l'on ne connaît pas.
- **Une liste priorisée des activités et services numériques critiques** : ce qui doit redémarrer en premier, et en combien de temps (objectifs de reprise).
- **Une analyse de risques** proportionnée : EBIOS Risk Manager (ANSSI) pour les structures matures, ou une approche simplifiée pour les PME.
- **Une politique de sécurité (PSSI)** courte et appliquée, et une **charte d'utilisation** signée par les utilisateurs.
- **Des procédures écrites** : arrivée/départ des personnes, gestion des comptes à privilèges, correctifs, sauvegarde/restauration, réponse à incident.
- **Une homologation** des systèmes importants : décision formelle d'accepter les risques résiduels.
- **Des clauses de sécurité** dans les contrats d'infogérance, d'hébergement et de cloud (notification d'incident, réversibilité, localisation des données, audit).

1.3 Les 5 mesures préventives prioritaires de l'ANSSI

L'ANSSI identifie cinq mesures dont la mise en œuvre rapide réduit fortement la probabilité et l'impact d'une cyberattaque. Elles doivent s'inscrire ensuite dans une démarche globale.

#	Mesure	Concrètement
1	Renforcer l'authentification	MFA sur tous les accès distants (VPN, webmail, cloud, bastion) et sur tous les comptes à privilèges ; suppression des comptes inutiles ; mots de passe robustes et uniques.
2	Accroître la supervision de sécurité	Centraliser les journaux, déployer un EDR, surveiller les alertes 24/7 ou via un prestataire (SOC).
3	Sauvegarder hors ligne	Au moins une copie des données et applications critiques déconnectée ou immuable, restauration testée.
4	Lister les services critiques	Inventaire priorisé des services numériques indispensables et de leurs dépendances.
5	Préparer la gestion de crise	Cellule de crise définie, annuaire hors ligne, procédures de fonctionnement dégradé, exercice annuel.

1.4 Socle d'hygiène : les 42 mesures en un coup d'œil

Le Guide d'hygiène informatique de l'ANSSI organise 42 mesures en 10 thèmes. Le tableau ci-dessous en donne une lecture opérationnelle ; le guide original détaille chaque mesure et distingue un niveau standard et un niveau renforcé.

Thème	Mesures clés
Sensibiliser et former	Former les équipes informatiques ; sensibiliser tous les utilisateurs ; maîtriser les risques de l'infogérance.
Connaître le SI	Inventaire des biens sensibles, des comptes privilégiés ; procédures d'arrivée/départ ; seuls les équipements maîtrisés se connectent au réseau.
Authentifier et contrôler les accès	Comptes nominatifs ; droits au strict besoin ; mots de passe robustes et protégés ; pas de mots de passe par défaut ; authentification forte.
Sécuriser les postes	Configuration de sécurité minimale ; protection contre les supports amovibles ; gestion centralisée ; pare-feu local ; chiffrement des données sensibles.
Sécuriser le réseau	Segmentation et cloisonnement ; Wi-Fi sécurisé ; protocoles sûrs ; passerelle Internet maîtrisée ; services exposés isolés (DMZ) ; réseau d'administration dédié.
Sécuriser l'administration	Interdire l'accès Internet aux comptes d'administration ; réseau et postes d'administration dédiés ; limiter les droits d'admin sur les postes.
Nomadisme	Sécurité physique des équipements mobiles ; chiffrement ; VPN ; politique smartphones.
Maintenir le SI à jour	Politique de mise à jour ; anticiper la fin de support des logiciels.
Superviser, auditer, réagir	Journalisation des composants critiques ; politique de sauvegarde ; audits réguliers ; référent sécurité ; procédure de gestion d'incident.
Pour aller plus loin	Démarche globale de gestion des risques ; recours à des produits et services qualifiés par l'ANSSI.

Référence

ANSSI — Guide d'hygiène informatique, 42 mesures : télécharger le PDF. Mesures préventives prioritaires : télécharger le PDF.

1.5 Feuille de route en trois vagues

Faute de pouvoir tout faire en même temps, ordonnez l'effort par réduction de risque. Les délais sont indicatifs pour une PME ; ils s'allongent avec la taille et la complexité du SI.

Vague	Objectif	Actions
0 à 30 jours	Fermer les portes les plus ouvertes	MFA sur accès distants et messagerie ; correctifs des équipements exposés ; fermeture des RDP/SMB exposés ; sauvegarde hors ligne testée ; comptes admin séparés ; inventaire des services exposés ; carte réflexe et contacts imprimés.
1 à 6 mois	Ralentir et voir l'attaquant	EDR sur postes et serveurs ; centralisation des journaux ; LAPS / mots de passe admin locaux uniques ; segmentation des serveurs, des postes et de l'administration ; durcissement AD et messagerie (SPF/DKIM/DMARC) ; sensibilisation.
6 à 18 mois	Rendre l'attaque coûteuse et la reprise rapide	Modèle d'administration en tiers ; postes d'administration dédiés ; bastion ; supervision 24/7 ; plan de continuité et de reprise ; exercice de crise ; audit externe ; analyse de risques.

PARTIE 2

Durcissement technique

Mesures détaillées par domaine : identités, Active Directory, postes, serveurs Linux et Windows, réseau, messagerie, exposition web, virtualisation, sauvegardes, journalisation et gestion des vulnérabilités. Chaque chapitre se termine par une liste de contrôle.

2.1 Identités, authentification et privilèges

La quasi-totalité des attaques graves passe par le vol ou l'abus d'un compte. Protéger les identités est la mesure au meilleur rapport coût/efficacité.

Authentification multifacteur (MFA)

- Obligatoire sur : VPN et accès distants, messagerie et suites cloud, consoles d'administration (hyperviseurs, pare-feu, cloud, sauvegarde, EDR), bastion, comptes à privilèges.
- Privilégier les facteurs **résistants à l'hameçonnage** : clés FIDO2/passkeys, cartes à puce. À défaut, application d'authentification avec correspondance de nombre. Éviter le SMS pour les comptes sensibles.
- Protéger aussi les **procédures de récupération** (réinitialisation par le support, numéros de secours) : c'est souvent là que l'attaquant contourne la MFA.
- Surveiller la « fatigue MFA » : rafales de demandes non sollicitées = mot de passe compromis.

Mots de passe

- Longueur avant complexité : au moins 12 caractères pour les utilisateurs avec MFA, 15 caractères et plus pour les comptes à privilèges ou sans second facteur ; phrases de passe encouragées.
- Mots de passe **uniques** par service, stockés dans un **gestionnaire de mots de passe** (ex. KeePassXC, ou une solution d'entreprise). Jamais de fichier texte ou de tableur.
- Bloquer les mots de passe connus compromis ou trop courants ; pas d'expiration arbitraire, mais changement immédiat en cas de soupçon.
- Changer **tous** les mots de passe par défaut (équipements réseau, imprimantes, caméras, IPMI/iDRAC/iLO, NAS).
- Comptes de service : mots de passe longs et aléatoires (25+ caractères) ou comptes de service gérés (gMSA).

Comptes et privilèges

- **Comptes nominatifs** : un compte = une personne. Pas de comptes génériques partagés.
- **Séparer** le compte utilisateur (messagerie, navigation) du compte d'administration. Un compte admin ne lit pas ses courriels et ne navigue pas sur Internet.
- **Moindre privilège** : pas de droits d'administration locale pour les utilisateurs ; élévation ponctuelle et tracée si nécessaire.
- **Mots de passe administrateur local uniques** sur chaque poste et serveur (Windows LAPS), pour empêcher la propagation latérale.
- **Revue trimestrielle** des comptes : désactivation des comptes de partants, comptes inactifs depuis plus de 90 jours, comptes de prestataires expirés.
- Comptes « bris de glace » : 2 comptes d'urgence très protégés, secrets sous enveloppe scellée/coffre, usage alerté.

☐ MFA actif sur 100 % des accès distants et comptes à privilèges.

☐ Gestionnaire de mots de passe déployé ; aucun mot de passe par défaut restant.

☐ Comptes admin distincts des comptes bureautiques ; aucun utilisateur admin local.

☐ Windows LAPS (ou équivalent) déployé sur postes et serveurs.

☐ Revue des comptes à privilèges et des comptes inactifs faite ce trimestre.

2.2 Active Directory : protéger le cœur du SI

L'ANSSI constate régulièrement que les compromissions de SI reposant sur Active Directory résultent de mauvaises pratiques d'administration et d'un cloisonnement insuffisant : l'attaquant part d'un poste, se déplace latéralement et élève ses privilèges jusqu'au contrôle total de l'annuaire, puis s'y ménage des portes dérobées.

Modèle d'administration en tiers

Tier	Contenu	Règle
Tier 0	Contrôleurs de domaine, AD CS (PKI), ADFS/Entra Connect, outils de gestion d'identité, consoles de sauvegarde/EDR/hyperviseurs ayant la main sur le Tier 0.	Administré uniquement depuis des postes d'administration Tier 0 dédiés, par des comptes Tier 0.
Tier 1	Serveurs et applications métier.	Comptes Tier 1 ; jamais d'ouverture de session Tier 0 sur ces machines.
Tier 2	Postes de travail et périphériques utilisateurs.	Comptes Tier 2 ; support poste via outils n'exposant pas les secrets.

Règle d'or

Un compte d'un tier supérieur ne doit **jamais** s'authentifier sur une machine d'un tier inférieur : un administrateur du domaine qui ouvre une session sur un poste compromis y laisse des secrets réutilisables par l'attaquant.

Mesures de durcissement prioritaires

- Réduire au strict minimum les membres de *Admins du domaine*, *Administrateurs de l'entreprise*, *Administrateurs*, *Opérateurs de compte/serveur/sauvegarde*, *DnsAdmins*. Cible : moins de 5 comptes Tier 0.
- Placer les comptes privilégiés dans le groupe **Protected Users** et activer « le compte est sensible et ne peut pas être délégué ».
- Supprimer la délégation Kerberos non contrainte ; inventorier les délégations contraintes et RBCD.
- Éliminer les comptes avec **SPN** et mot de passe faible (Kerberoasting) et les comptes sans pré-authentification Kerberos (AS-REP roasting).
- Désactiver **NTLMv1** et LM ; auditer puis restreindre NTLM ; imposer la signature SMB et LDAP, et le channel binding LDAPS.
- Désactiver le service Spouleur d'impression sur les contrôleurs de domaine.
- Auditer les **modèles de certificats AD CS** (vulnérabilités de type ESC1 à ESC8).
- Contrôler les **ACL** dangereuses (GenericAll, WriteDACL, DCSync accordés à tort) et les GPO modifiables par des non-administrateurs.
- Renouveler le mot de passe du compte **krbtgt** régulièrement (deux fois, en laissant la réplication se faire entre les deux) et systématiquement après une compromission.
- Mettre les niveaux fonctionnels à jour et retirer les contrôleurs de domaine obsolètes.
- Activer la corbeille AD et sauvegarder l'état système des contrôleurs de domaine (hors ligne).

Auditer son AD gratuitement

- **Service ADS de l'ANSSI** (audit d'annuaire pour les bénéficiaires éligibles) : messervices.cyber.gouv.fr/services/ads.
- **ORADAD** (ANSSI, collecte des données AD) : github.com/ANSSI-FR.
- Outils communautaires reconnus : PingCastle (rapport de risques AD), BloodHound (chemins d'attaque), Purple Knight. À exécuter avec l'accord de la direction et en environnement maîtrisé.

☐ Moins de 5 comptes dans les groupes Tier 0 ; tous dans Protected Users.

☐ Aucun compte Tier 0 ne se connecte sur un poste ou un serveur métier.

☐ Pas de délégation non contrainte ; pas de Kerberoasting possible sur des comptes privilégiés.

☐ NTLMv1 désactivé ; signature SMB/LDAP imposée ; Spouleur arrêté sur les DC.

☐ Audit AD (ADS, PingCastle ou équivalent) réalisé dans l'année et plan d'action suivi.

2.3 Postes de travail Windows

- **Mises à jour automatiques** du système, des navigateurs, des suites bureautiques et des lecteurs PDF.
- **EDR** (détection et réponse) plutôt qu'un simple antivirus ; Microsoft Defender correctement configuré est un minimum, avec la protection contre la falsification activée.
- **Chiffrement BitLocker** avec TPM (+ code PIN pour les portables les plus sensibles) ; clés de récupération sauvegardées hors du poste.
- **Règles de réduction de la surface d'attaque (ASR)** : bloquer les processus enfants d'Office, le vol d'identifiants LSASS, les exécutables issus de la messagerie, etc. Commencer en mode audit.
- **Restriction logicielle** : AppLocker ou WDAC, au minimum interdire l'exécution depuis les dossiers utilisateurs (Téléchargements, AppData, Temp).
- **Protection des secrets** : Credential Guard, protection LSA (RunAsPPL) ; désactiver WDigest.
- **Macros Office** bloquées pour les fichiers venant d'Internet ; désactiver les protocoles et composants inutiles (SMBv1, PowerShell v2, LLMNR, NetBIOS sur TCP/IP, WPAD si inutilisé).
- **PowerShell** : journalisation des blocs de script et transcription activées.
- **Pare-feu local** actif : bloquer les flux entrants poste à poste (SMB, RDP, WinRM) qui servent à la propagation.
- **Supports amovibles** : exécution automatique désactivée ; analyse ou station blanche pour les clés externes.

> **Référence**
> ANSSI — Mettre en œuvre une politique de restrictions logicielles sous Windows ; Mise en œuvre des fonctionnalités de sécurité de Windows 10 reposant sur la virtualisation ; catalogue complet : messervices.cyber.gouv.fr/catalogue.

2.4 Serveurs Linux (entreprise et personnel)

Ce chapitre suit la logique du guide ANSSI « Recommandations de configuration d'un système GNU/Linux » : principes de minimisation et de défense en profondeur, configuration matérielle, installation, services et cloisonnement. L'ANSSI publie un rôle Ansible d'exemple, « Actionnable Linux », pour implémenter une partie des recommandations : github.com/ANSSI-FR/actionnable-linux.

Principes

- **Minimisation** : installer uniquement les paquets nécessaires ; un serveur = un rôle ; désinstaller compilateurs et outils réseau superflus en production.
- **Moindre privilège** : services sous comptes dédiés non privilégiés ; pas de connexion root directe.
- **Défense en profondeur** : pare-feu local + contrôle d'accès obligatoire (SELinux ou AppArmor) + journalisation + mises à jour.
- **Matériel et démarrage** : UEFI Secure Boot, mot de passe du firmware, désactivation des périphériques inutiles, chiffrement des disques (LUKS) si le serveur peut être volé.

Mises à jour

```
mises à jour automatiques


# Debian / Ubuntu : correctifs de sécurité automatiques
apt install unattended-upgrades apt-listchanges
dpkg-reconfigure -plow unattended-upgrades

# RHEL / Rocky / Alma : dnf-automatic limité aux correctifs de sécurité
dnf install dnf-automatic
# /etc/dnf/automatic.conf : upgrade_type = security ; apply_updates = yes
systemctl enable --now dnf-automatic.timer
```

SSH : configuration durcie

```
sshd_config


# /etc/ssh/sshd_config.d/99-durcissement.conf  — tester avant de fermer la session courante !
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no
PubkeyAuthentication yes
PermitEmptyPasswords no
AllowGroups ssh-users            # seuls les membres de ce groupe peuvent se connecter
MaxAuthTries 3
LoginGraceTime 30
ClientAliveInterval 300
ClientAliveCountMax 2
X11Forwarding no
AllowAgentForwarding no
AllowTcpForwarding no            # à ouvrir uniquement si nécessaire
LogLevel VERBOSE                 # journalise l'empreinte des clés utilisées

# Vérifier puis recharger :
#   sshd -t && systemctl reload ssh   (ou sshd selon la distribution)
```

- Clés **Ed25519** protégées par phrase de passe, idéalement sur clé matérielle (FIDO2 : `ssh-keygen -t ed25519-sk`).
- Ne **jamais** exposer SSH directement sur Internet pour un serveur personnel : passer par un VPN (WireGuard) ou, à défaut, restreindre par adresse IP et ajouter fail2ban/CrowdSec.
- Revoir régulièrement les fichiers `~/.ssh/authorized_keys` de tous les comptes, y compris root.

Noyau et système de fichiers

```
sysctl et montages

# /etc/sysctl.d/90-durcissement.conf   (appliquer : sysctl --system)
kernel.kptr_restrict = 2
kernel.dmesg_restrict = 1
kernel.yama.ptrace_scope = 1
kernel.randomize_va_space = 2
kernel.unprivileged_bpf_disabled = 1
fs.protected_symlinks = 1
fs.protected_hardlinks = 1
fs.protected_fifos = 2
fs.protected_regular = 2
fs.suid_dumpable = 0
net.ipv4.tcp_syncookies = 1
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.all.log_martians = 1
net.ipv6.conf.all.accept_redirects = 0
net.ipv4.ip_forward = 0          # sauf routeur / hôte de conteneurs

# /etc/fstab : partitions séparées et options restrictives (exemple)
# /tmp      ...  nodev,nosuid,noexec
# /var/tmp  ...  nodev,nosuid,noexec
# /home     ...  nodev,nosuid
# /dev/shm  ...  nodev,nosuid,noexec
```

Comptes, sudo et contrôle d'accès

- Administration via `sudo` avec des règles précises ; éviter `NOPASSWD` et les commandes permettant un shell (éditeurs, `find`, interpréteurs).
- Vérifier qu'aucun autre compte que root n'a l'UID 0 : `awk -F: '$3==0' /etc/passwd`.
- Laisser **SELinux en mode enforcing** (RHEL et dérivés) ou **AppArmor** actif (Debian/Ubuntu) ; ne pas le désactiver pour « faire marcher » une application : écrire la politique.
- Recenser les binaires setuid/setgid et retirer ceux qui sont inutiles : `find / -xdev -perm /6000 -type f`.
- Durcir les services avec les options systemd : `ProtectSystem=strict, ProtectHome=yes, PrivateTmp=yes, NoNewPrivileges=yes, CapabilityBoundingSet=`. Évaluer avec `systemd-analyze security`.

Pare-feu, journalisation et intégrité

```
pare-feu et audit

# nftables : politique par défaut « tout refuser » en entrée (exemple minimal)
table inet filter {
  chain input {
    type filter hook input priority 0; policy drop;
    iif lo accept
    ct state established,related accept
    ct state invalid drop
    ip saddr 192.0.2.0/24 tcp dport 22 accept     # SSH depuis le réseau d'admin uniquement
    tcp dport { 80, 443 } accept                   # si serveur web
    icmp type echo-request limit rate 5/second accept
    meta l4proto ipv6-icmp accept                  # indispensable au fonctionnement d'IPv6
  }
}

# Journalisation : auditd + envoi vers un collecteur central
apt install auditd          # ou dnf install audit
# règles : modifications de /etc/passwd, /etc/shadow, /etc/sudoers, sshd_config,
#          exécutions en root, chargement de modules noyau
# Intégrité des fichiers : AIDE (aide --init puis aide --check planifié)
```

- ☐ Installation minimale, un rôle par serveur, mises à jour de sécurité automatiques.
- ☐ SSH : clés uniquement, root interdit, accès limité au réseau d'administration ou VPN.
- ☐ sysctl et options de montage durcis ; SELinux/AppArmor actifs.
- ☐ Pare-feu en politique de refus par défaut ; seuls les ports nécessaires ouverts.
- ☐ auditd actif et journaux envoyés hors du serveur ; contrôle d'intégrité (AIDE).
- ☐ Évaluation de conformité régulière (ex. profil ANSSI BP-028 d'OpenSCAP, ou Lynis).

> **Pour aller plus loin**
>
> ANSSI — Configuration d'un système GNU/Linux v2.0 : PDF ; Usage sécurisé d'(Open)SSH : page du guide ; Cloisonnement système : page du guide.

2.5 Serveurs Windows

- Préférer **Server Core** quand c'est possible (surface d'attaque réduite) ; un rôle par serveur.
- Appliquer une **ligne de base de sécurité** (Microsoft Security Baselines, profils CIS) via GPO, après test.
- **RDP** : jamais exposé sur Internet ; NLA obligatoire ; accès uniquement depuis le réseau d'administration ou un bastion ; mode Restricted Admin ou Remote Credential Guard pour les administrateurs.
- Désactiver SMBv1, imposer la signature SMB ; restreindre WinRM et les partages administratifs aux machines d'administration.
- Pas de navigation Internet ni de messagerie depuis un serveur.
- EDR, journalisation avancée (voir 2.10) et sauvegarde de l'état système.

> **Référence**
>
> ANSSI — Mise en œuvre sécurisée d'un serveur Windows : page du guide.

2.6 Réseau, cloisonnement et accès distants

Architecture

- **Segmenter** en zones (VLAN + filtrage entre zones) : postes utilisateurs, serveurs, administration, DMZ (services exposés), invités, IoT/imprimantes/vidéo, sauvegardes, systèmes industriels.
- **Filtrer par liste blanche** entre zones : tout ce qui n'est pas explicitement autorisé est refusé. Les postes n'ont pas à se parler entre eux.
- **Réseau d'administration dédié** : les interfaces d'administration (hyperviseurs, iDRAC/iLO, équipements réseau, sauvegarde) ne sont joignables que depuis ce réseau.
- **Passerelle Internet maîtrisée** : proxy filtrant pour la navigation, résolution DNS contrôlée (résolveur interne, journalisé), sortie directe des serveurs vers Internet interdite par défaut.
- **Services exposés** en DMZ, derrière reverse proxy/WAF ; aucun service interne (RDP, SMB, bases de données, interfaces d'admin) publié directement.

Accès distants

- VPN avec MFA, maintenu à jour en priorité absolue : les passerelles VPN et pare-feu sont parmi les équipements les plus ciblés dès la publication d'une vulnérabilité.
- Accès des prestataires : comptes nominatifs, MFA, ouverts à la demande et limités dans le temps, via bastion avec enregistrement des sessions.
- Inventorier périodiquement la **surface exposée** (ports ouverts depuis Internet, sous-domaines, certificats). Le service Silène de l'ANSSI aide les organisations éligibles à cartographier leur exposition.

Wi-Fi

- Entreprise : WPA3-Entreprise (ou WPA2-Entreprise) avec 802.1X et certificats ; réseau invité isolé, sans accès interne.
- Désactiver WPS ; changer les identifiants d'administration des bornes ; mettre à jour leur firmware.

☐ Aucun RDP, SMB, base de données ou interface d'administration exposé sur Internet (vérifié depuis l'extérieur).

☐ Zones séparées et filtrées ; postes isolés entre eux ; réseau d'administration dédié.

☐ VPN et pare-feu à jour, MFA activée, journaux conservés.

☐ Sorties Internet des serveurs restreintes ; DNS interne journalisé.

Références

ANSSI — Interconnexion d'un SI à Internet : page ; Politique de filtrage d'un pare-feu : page ; Administration sécurisée des SI : page ; Wi-Fi : page.

2.7 Messagerie et suites collaboratives (M365, Google Workspace)

- MFA pour tous ; **désactiver les protocoles d'authentification hérités** (POP, IMAP, SMTP AUTH basique) qui contournent la MFA.
- Accès conditionnel : bloquer les connexions depuis des pays ou appareils non attendus ; exiger un appareil géré pour les administrateurs.
- Alertes sur : création de **règles de transfert ou de suppression** de courriels, consentement à des applications OAuth, connexions impossibles (« voyage impossible »), ajout de méthodes MFA.
- Interdire le transfert automatique vers l'extérieur par défaut.
- Activer et conserver les journaux d'audit unifiés ; comptes « bris de glace » exclus de l'accès conditionnel mais surveillés.
- Filtrage antispam/antimalware avec analyse des pièces jointes et des liens ; bannière « expéditeur externe ».

Authentification du domaine de messagerie

```
DNS — SPF / DKIM / DMARC (exemples)

; SPF : seuls ces émetteurs peuvent envoyer pour le domaine
exemple.fr.          TXT  "v=spf1 include:spf.fournisseur-mail.example -all"

; DKIM : signature cryptographique (clé publiée par le fournisseur de messagerie)
selecteur._domainkey TXT  "v=DKIM1; k=rsa; p=MIIBIjANBgkq..."

; DMARC : commencer en p=none pour observer, puis quarantine, puis reject
_dmarc.exemple.fr.   TXT  "v=DMARC1; p=reject; rua=mailto:dmarc@exemple.fr; adkim=s; aspf=s"

; Domaine qui n'envoie JAMAIS de courriel : le verrouiller
autre-domaine.fr.         TXT "v=spf1 -all"
_dmarc.autre-domaine.fr.  TXT "v=DMARC1; p=reject"
```

> **Fraude au virement**
> Aucune modification de coordonnées bancaires ni aucun virement urgent ne doit être validé sur la seule base d'un courriel : rappel systématique de l'interlocuteur sur un numéro connu à l'avance (jamais celui indiqué dans le message) et double validation.

2.8 Sites web, applications et services exposés

- **Inventaire** de tout ce qui est exposé : sites, API, sous-domaines oubliés, environnements de test.
- **CMS** (WordPress, Drupal, Joomla…) : cœur, thèmes et extensions à jour ; supprimer ce qui est inutilisé ; interface d'administration restreinte (IP/VPN) et protégée par MFA.
- **TLS** : TLS 1.2 minimum, TLS 1.3 recommandé ; certificats renouvelés automatiquement (ACME) ; HSTS.
- **En-têtes de sécurité** : Content-Security-Policy, X-Content-Type-Options: nosniff, frame-ancestors / X-Frame-Options, Referrer-Policy.
- **Application** : requêtes paramétrées, contrôle d'accès vérifié côté serveur sur chaque objet (failles de type IDOR), gestion sûre des sessions, aucun secret dans le code ou le dépôt Git.
- **Base de données** : jamais exposée sur Internet ; compte applicatif aux droits minimaux.
- Pare-feu applicatif (WAF) et protection anti-DDoS selon l'exposition ; sauvegarde du site et de sa base hors du serveur.

- Référentiels : OWASP Top 10 et OWASP ASVS pour le développement ; guides ANSSI « Sécuriser un site web », « Mise en œuvre sécurisée d'un CMS », « Se protéger des failles de type IDOR », « Recommandations de sécurité relatives à TLS ».

2.9 Virtualisation, conteneurs et cloud

Hyperviseurs (VMware ESXi, Proxmox, Hyper-V)

Les hyperviseurs sont devenus une cible prioritaire des rançongiciels : chiffrer un seul hôte arrête d'un coup toutes ses machines virtuelles.

- Interfaces de gestion (vCenter, ESXi, Proxmox, iDRAC/iLO) accessibles **uniquement** depuis le réseau d'administration.
- Éviter de rattacher les hyperviseurs et la console de gestion au domaine AD de production, ou maîtriser très précisément les groupes AD qui y donnent des droits.
- SSH/ESXi Shell désactivés hors maintenance ; mode verrouillage (lockdown) ; MFA sur la console.
- Correctifs appliqués rapidement ; journaux envoyés vers un collecteur externe.
- Sauvegardes des VM avec des identifiants distincts et une copie hors ligne/immuable.

Conteneurs (Docker, Podman, Kubernetes)

```
docker run durci


# Lancer un conteneur avec un minimum de privilèges (exemple Docker)
docker run -d --name app \
  --user 10001:10001 \
  --read-only --tmpfs /tmp \
  --cap-drop ALL \
  --security-opt no-new-privileges:true \
  --pids-limit 200 --memory 512m --cpus 1 \
  -p 127.0.0.1:8080:8080 \
  registre.interne/app@sha256:

# À proscrire : --privileged, -v /var/run/docker.sock:..., --net=host, image "latest" non vérifiée
```

- Images minimales, d'origine maîtrisée, épinglées par empreinte et analysées (ex. Trivy) ; reconstruites régulièrement.
- Secrets injectés par un gestionnaire de secrets, jamais dans l'image ni dans le dépôt.
- Mode rootless (Docker/Podman) quand c'est possible ; les membres du groupe *docker* sont de fait administrateurs de l'hôte.
- Kubernetes : RBAC strict, Pod Security « restricted », NetworkPolicies, API non exposée.

Cloud public et SaaS

- Comptes racine/super-admin protégés par MFA matérielle et non utilisés au quotidien.
- Journaux d'activité (CloudTrail, Azure Activity/Entra, Google Audit) activés et exportés.
- Aucun stockage objet public par défaut ; revue des partages publics de documents.
- Pour les données sensibles : offres qualifiées SecNumCloud (doctrine ANSSI pour l'hébergement des SI sensibles).

2.10 Journalisation, supervision et détection

Sans journaux, il est impossible de détecter une intrusion, d'en comprendre l'étendue ou d'apporter la preuve d'un événement. La journalisation doit être pensée avant l'incident.

- **Horodatage fiable** : toutes les machines synchronisées sur une source NTP commune.
- **Centralisation** sur un collecteur protégé, hors du domaine AD de production si possible, en écriture seule depuis les sources : un attaquant efface les journaux locaux.
- **Rétention** : au moins 6 mois, idéalement 1 an pour les journaux de sécurité ; la détection d'une intrusion intervient souvent des semaines après les faits.
- **Sources prioritaires** : contrôleurs de domaine, VPN, pare-feu, proxy, DNS, messagerie, EDR, serveurs exposés, hyperviseurs, sauvegardes, bastion, cloud.
- **Sysmon** sur les postes et serveurs Windows (avec une configuration communautaire reconnue) pour tracer processus, connexions réseau et persistance.
- **Détection** : EDR + SIEM ou SOC externalisé ; des alertes qui sont réellement lues et traitées.

Événements Windows à surveiller en priorité

ID	Journal	Signification et intérêt
4624 / 4625	Sécurité	Ouverture de session réussie / échouée. Type 10 = RDP, type 3 = réseau. Rafales d'échecs = attaque par mot de passe.
4648	Sécurité	Connexion avec identifiants explicites (runas, latéralisation).
4672	Sécurité	Session avec privilèges spéciaux (compte admin) : à corréler avec les machines autorisées.
4688	Sécurité	Création de processus (activer la ligne de commande dans la stratégie d'audit).
4697 / 7045	Sécurité / Système	Installation d'un service : persistance ou exécution à distance (PsExec).
4698	Sécurité	Création d'une tâche planifiée : persistance fréquente.
4720 / 4722 / 4724	Sécurité	Compte créé / activé / mot de passe réinitialisé.
4728 / 4732 / 4756	Sécurité	Ajout à un groupe global / local / universel : surveiller les groupes à privilèges.
4740	Sécurité	Compte verrouillé.
4768 / 4769 / 4771	Sécurité (DC)	Kerberos : TGT, ticket de service (Kerberoasting si RC4 en masse), échec de pré-authentification.
4776	Sécurité (DC)	Validation NTLM.
1102 / 104	Sécurité / Système	Journal effacé : signal fort d'activité malveillante.
4104	PowerShell/Operational	Bloc de script PowerShell (contenu des scripts exécutés).

Linux : où regarder

- `/var/log/auth.log` (Debian/Ubuntu) ou `/var/log/secure` (RHEL) ; `journalctl` ; journaux auditd (`ausearch`, `aureport`) ; `last`, `lastb`, `wtmp/btmp` ; journaux applicatifs (web, base de données).
- Signaux d'alerte : connexion root, nouvelle clé SSH autorisée, nouveau compte ou sudoer, nouvelle tâche cron ou unité systemd, binaire modifié, connexion sortante inhabituelle, processus consommant beaucoup de CPU (minage).

Références

ANSSI — Architecture d'un système de journalisation : page ; Journalisation dans un environnement Active Directory : page ; La supervision de sécurité : page.

2.11 Sauvegardes et capacité de reprise

La sauvegarde est la dernière ligne de défense contre le rançongiciel, et c'est pour cela que les attaquants cherchent systématiquement à la détruire avant de chiffrer.

Règle 3-2-1-1-0

3 copies des données, sur **2** supports différents, dont **1** hors site, dont **1** hors ligne ou immuable, et **0** erreur lors des tests de restauration.

- **Identifiants distincts** : le serveur et la console de sauvegarde ne dépendent pas de l'AD de production ; MFA sur la console ; comptes non réutilisés ailleurs.
- **Copie hors ligne** (bande, disque déconnecté) ou **immuable** (verrouillage WORM, stockage objet avec Object Lock) que l'administrateur lui-même ne peut pas supprimer avant échéance.
- **Périmètre** : données, mais aussi configurations (pare-feu, commutateurs), état système des contrôleurs de domaine, hyperviseurs, scripts de déploiement, documentation et secrets d'urgence.
- **Objectifs définis** par service : perte de données maximale admissible (RPO) et durée d'interruption maximale (RTO).
- **Tests de restauration** au moins trimestriels, y compris un scénario « tout le SI est perdu » (dans quel ordre redémarre-t-on, avec quels prérequis ?).
- Chiffrement des sauvegardes ; clé de déchiffrement conservée hors du SI.
- Alerte en cas d'échec de sauvegarde, de suppression massive ou de modification de la politique de rétention.

Référence

ANSSI — Fondamentaux de la sauvegarde des SI : page du guide.

2.12 Gestion des vulnérabilités et des correctifs

Priorité	Cible	Délai indicatif
Critique	Vulnérabilité activement exploitée sur un équipement exposé à Internet (VPN, pare-feu, passerelle, messagerie, serveur web) ; alerte CERT-FR.	Immédiat : heures à 48 h. Si aucun correctif n'existe : mesure de contournement ou retrait d'Internet.
Haute	Vulnérabilité critique non exploitée sur un système exposé, ou exploitée sur un système interne (AD, hyperviseur).	Moins de 7 jours.
Moyenne	Autres correctifs de sécurité des systèmes internes.	Cycle mensuel.
Fin de support	Systèmes et logiciels sans correctifs (OS obsolètes, firmwares abandonnés).	Plan de remplacement ; en attendant, isolement réseau strict.

- Veille : alertes et avis du CERT-FR (cert.ssi.gouv.fr), bulletins des éditeurs, catalogue des vulnérabilités exploitées (CISA KEV).

- Après une alerte sur un équipement exposé : **corriger ne suffit pas**, rechercher aussi des traces de compromission antérieure au correctif (les CERT publient souvent des indicateurs).
- Scanner régulièrement son propre périmètre (scanner de vulnérabilités interne et externe).

2.13 Facteur humain, prestataires et nomadisme

- **Sensibilisation** courte et régulière plutôt qu'annuelle et longue ; exercices d'hameçonnage bienveillants ; un canal simple pour signaler un message suspect, sans crainte de reproche.
- **Formation** spécifique des administrateurs (MOOC SecNumacadémie de l'ANSSI, gratuit).
- **Départs** : désactivation des accès le jour même, récupération du matériel, changement des secrets partagés connus.
- **Prestataires et infogérants** : inventaire de leurs accès, MFA, traçabilité, clauses de notification d'incident ; ils sont une porte d'entrée fréquente.
- **Nomadisme et déplacements** : postes chiffrés, VPN systématique, filtre de confidentialité, vigilance dans les transports et à l'étranger (guide ANSSI « Bonnes pratiques à l'usage des professionnels en déplacement »).
- **Téléphones** : verrouillage fort, mises à jour, applications des magasins officiels, gestion de flotte (MDM) pour les appareils professionnels.

PARTIE 3

Données personnelles et obligations

La sécurité est aussi une obligation légale. Le RGPD impose des mesures techniques et organisationnelles appropriées et la notification des violations ; la directive NIS 2 étend les obligations de cybersécurité à de nombreuses entreprises et administrations.

3.1 RGPD : l'obligation de sécurité

L'article 32 du RGPD impose au responsable de traitement et au sous-traitant de mettre en œuvre des mesures garantissant un niveau de sécurité adapté au risque. Le Guide de la sécurité des données personnelles de la CNIL (25 fiches en 5 parties) est le guide de référence utilisé par la CNIL pour apprécier la sécurité des traitements.

- Identifier les traitements et leurs risques pour les personnes (registre, analyse d'impact si nécessaire).
- Minimiser : ne collecter et ne conserver que le nécessaire ; purger selon les durées de conservation.
- Chiffrer les données sensibles au repos et en transit ; pseudonymiser quand c'est possible.
- Tracer les accès aux données (journalisation) et les conserver de façon proportionnée.
- Encadrer les sous-traitants (article 28) : clauses de sécurité et de notification.
- Développeurs : guide RGPD de l'équipe de développement de la CNIL, sur GitHub.

3.2 Violation de données : que faire ?

Étape	Obligation	Délai
Documenter	Toute violation est inscrite au registre interne des violations (faits, effets, mesures prises), même si elle n'est pas notifiée.	Toujours
Notifier la CNIL	Si la violation présente un risque pour les droits et libertés des personnes. Notification en ligne ; une notification initiale peut être complétée ensuite.	72 h après en avoir pris connaissance
Informer les personnes	Si le risque est élevé (données sensibles, bancaires, identifiants…) : information claire et conseils (changer de mot de passe, vigilance hameçonnage).	Dans les meilleurs délais

> **Bon réflexe**
> En cas de doute sur l'exfiltration, effectuez une notification initiale en précisant qu'une compromission est possible mais non confirmée, puis complétez-la. Formulaire : cnil.fr/fr/notifier-une-violation-de-donnees-personnelles.

3.3 Plainte, assurance et NIS 2

- **Plainte** : elle déclenche l'enquête, peut permettre d'identifier les auteurs et documente votre situation de victime. En France, l'indemnisation par l'assurance des pertes liées à une cyberattaque est conditionnée à un dépôt de plainte au plus tard **72 heures** après la connaissance de l'atteinte (Code des assurances, issu de la loi LOPMI de 2023).
- **Assurance cyber** : déclarer rapidement le sinistre ; l'assureur peut mandater ou recommander des prestataires.
- **NIS 2** : la directive européenne prévoit pour les entités essentielles et importantes une alerte précoce sous 24 h, une notification d'incident sous 72 h et un rapport final sous un mois pour les incidents importants. Vérifiez votre statut et vos obligations nationales (France : messervices.cyber.gouv.fr/nis2 ; Belgique : CCB et référentiel CyberFundamentals ; Suisse : obligation d'annonce à l'OFCS pour les infrastructures critiques).
- **Secteurs réglementés** (santé, finance, énergie, transport…) : obligations complémentaires ; dans le doute, consulter le service juridique.

PARTIE 4

Sécuriser chez soi

Réseau domestique, appareils, comptes en ligne, NAS et serveurs auto-hébergés. Les principes sont les mêmes qu'en entreprise, à une échelle plus simple.

4.1 Les comptes : la priorité absolue

1. **Sécuriser d'abord la messagerie principale** : c'est la clé qui permet de réinitialiser tous les autres comptes. Mot de passe unique, long, et double authentification.
2. **Gestionnaire de mots de passe** (ex. KeePassXC, ou un service reconnu) : un mot de passe différent par site, généré aléatoirement.
3. **Double authentification** partout où c'est possible : messagerie, banque, réseaux sociaux, cloud, comptes administratifs, boutiques. Privilégier une application ou une clé de sécurité au SMS.
4. **Codes de secours** imprimés et rangés en lieu sûr.
5. Vérifier si ses adresses figurent dans des fuites connues et changer les mots de passe concernés.

4.2 Box, Wi-Fi et réseau domestique

- ☐ Mot de passe d'administration de la box changé ; firmware à jour.
- ☐ Wi-Fi en WPA3 (ou WPA2-AES à défaut) avec une phrase de passe longue ; WPS désactivé.
- ☐ UPnP désactivé sur la box (il permet à n'importe quel appareil d'ouvrir des ports vers Internet).
- ☐ Réseau invité séparé pour les visiteurs et pour les objets connectés (caméras, prises, TV, assistants).
- ☐ Aucune redirection de port inutile ; liste des redirections vérifiée.
- ☐ Administration à distance de la box désactivée.

4.3 Appareils

- Mises à jour automatiques du système, du navigateur et des applications sur ordinateurs et téléphones.
- Compte utilisateur standard au quotidien ; compte administrateur réservé aux installations.
- Antivirus intégré activé (Microsoft Defender, XProtect) ; pare-feu local actif.
- Chiffrement du disque (BitLocker, FileVault, LUKS) et verrouillage automatique.
- Applications uniquement depuis les magasins officiels ou les sites des éditeurs ; jamais de logiciels piratés.
- Objets connectés : changer les mots de passe par défaut, mettre à jour, désactiver l'accès cloud non nécessaire.
- Téléphone : code robuste, biométrie, sauvegarde chiffrée ; guide ANSSI « Hygiène numérique des téléphones mobiles » : page du guide.

4.4 NAS, homelab et serveurs auto-hébergés

> **Le principe à retenir**
> Ne rien exposer directement sur Internet qui ne soit pas conçu et maintenu pour l'être. Pour accéder à son réseau de l'extérieur, passer par un **VPN** (WireGuard) plutôt que par des redirections de ports vers SSH, RDP, l'interface du NAS ou de l'hyperviseur.

- **NAS** : désactiver les fonctions d'accès distant « facile » non utilisées ; mises à jour ; comptes nominatifs ; compte admin par défaut désactivé ; **instantanés** (snapshots) en lecture seule planifiés ; une copie de sauvegarde ailleurs que sur le NAS.
- **Services publiés** (site, cloud perso, domotique) : derrière un reverse proxy avec TLS, authentification forte, mises à jour suivies ; dans un VLAN/DMZ séparé du reste du réseau.
- **Serveurs Linux** : appliquer le chapitre 2.4 (SSH par clé, pare-feu, mises à jour automatiques, fail2ban/CrowdSec si un service est exposé).
- **Conteneurs** : appliquer le chapitre 2.9 ; ne pas monter le socket Docker dans un conteneur exposé.

- **Hyperviseur** (Proxmox, ESXi) : interface de gestion jamais exposée ; sauvegarde des VM hors de l'hôte.
- **Supervision légère** : notifications de connexion SSH, alertes de mises à jour, surveillance des journaux.

4.5 Sauvegardes personnelles

- Appliquer la règle 3-2-1 : par exemple, données sur l'ordinateur + disque externe débranché après usage + copie chiffrée dans un service en ligne.
- Tester la restauration d'un fichier au moins une fois par trimestre.
- Photos et documents administratifs : priorité absolue, ce sont les données irremplaçables.

4.6 Particulier victime : premiers réflexes

Situation	Que faire
Compte piraté	Changer le mot de passe depuis un appareil sain ; activer la double authentification ; déconnecter toutes les sessions ; vérifier les adresses et numéros de récupération, les règles de transfert de courriel ; prévenir ses contacts ; changer les mots de passe réutilisés ailleurs.
Rançongiciel	Débrancher l'appareil du réseau sans l'éteindre ; ne pas payer ; photographier la demande de rançon ; vérifier sur nomoreransom.org si un outil de déchiffrement existe ; restaurer depuis une sauvegarde saine ; porter plainte.
Hameçonnage avec saisie de coordonnées bancaires	Faire opposition immédiatement auprès de sa banque ; contester les opérations ; porter plainte.
Faux support technique	Ne pas appeler le numéro ; fermer le navigateur (au besoin redémarrer) ; si un accès à distance a été accordé : déconnecter, faire analyser l'appareil, changer les mots de passe.
Chantage / sextorsion	Ne pas répondre ni payer ; conserver les preuves ; signaler et porter plainte.

Aide gratuite

Cybermalveillance.gouv.fr propose un diagnostic en ligne et des fiches réflexes par type d'attaque, et met en relation avec des professionnels de proximité : cybermalveillance.gouv.fr/17cyber. Fiche « Les essentiels de votre sécurité numérique » : PDF.

PARTIE 5

Réagir à une compromission

Qualifier, endiguer, préserver, investiguer, remédier, reconstruire. Cette partie suit la logique des fiches réflexes du CERT-FR et du corpus « Cyberattaques et remédiation » de l'ANSSI. Elle est conçue pour être imprimée et utilisée sans accès au SI.

5.1 Organisation et principes de la réponse

Principe	Pourquoi
Main courante dès la première minute	Chaque ligne : date et heure (préciser le fuseau), personne, action ou événement, machines concernées. Elle sert à coordonner, à mesurer l'efficacité des actions et au retour d'expérience. À tenir hors du SI compromis (papier, cloud externe, outil de gestion d'incident).
Considérer l'attaquant comme présent et attentif	Il peut lire les courriels, observer les tickets, réagir à vos actions et déclencher le chiffrement plus tôt.
Communiquer hors bande	Téléphones, messagerie et visioconférence hors du SI ; liste de contacts imprimée.
Préserver avant de nettoyer	Une réinstallation hâtive efface la preuve du point d'entrée : l'attaquant revient par le même chemin.
Se faire aider tôt	Prestataire de réponse à incident (qualifié PRIS pour les SI complexes), CSIRT régional, Cybermalveillance.gouv.fr ; assureur ; CERT-FR pour les entités concernées.

Niveaux de gravité (CERT-FR)

Niveau	Description
Anomalie courante	Pas de menace sérieuse ni d'impact significatif, mais doit être qualifiée pour le confirmer.
Incident mineur	Menace limitée ; impact modéré, avéré ou possible, sur l'activité.
Incident majeur	Menace sérieuse ; impact fort, avéré ou possible, sur l'activité.
Crise cyber	Périmètre étendu sur le SI, impact fort et résolution urgente : activer le dispositif de gestion de crise.

Rôles minimaux

- **Décideur** (direction) : arbitre entre continuité d'activité et sécurité, valide la communication et les dépenses.
- **Pilote de l'incident** : coordonne, tient la main courante, fixe les points de situation.
- **Équipe technique** : qualification, endiguement, préservation, en lien avec le prestataire.
- **Communication et juridique** : messages internes et externes, déclarations, relations avec l'assureur.
- **Métiers** : activation des modes dégradés (travail sur papier, procédures manuelles).

5.2 Qualifier l'incident

Objectif : confirmer qu'un incident est en cours et en évaluer la gravité, **en temps contraint**. Des réponses approximatives ou « je ne sais pas » sont acceptables à ce stade ; une qualification plus fine viendra ensuite.

Mesure	Questions à se poser
1. Identifier le système	L'adresse IP ou le nom signalé correspond-il à une machine connue (DHCP, inventaire, AD) ? S'agit-il d'un équipement relais (proxy, pare-feu, NAT, DNS) qui en masque d'autres ? Quel OS, quel niveau de correctifs, quelles applications, un logiciel vulnérable activement exploité ? L'horodatage et le fuseau du signalement sont-ils cohérents ?
2. Confirmer la compromission	Le flux est-il visible dans les journaux du pare-feu/proxy ou détecté par une sonde ? L'EDR ou l'antivirus confirme-t-il le code malveillant ? Des flux inhabituels partent-ils de la machine (VPS, Tor, ports rares, scans internes, tentatives RDP/SSH) ? Faux positif ou investigation à poursuivre ?

Mesure	Questions à se poser
3. Évaluer le périmètre	Rôle de la machine (poste, serveur, hyperviseur, appliance) ? Est-elle exposée sur Internet, reliée à des partenaires, pont vers des zones sensibles ? D'autres machines présentent-elles les mêmes anomalies ? Des ressources d'administration (comptes, postes, serveurs) sont-elles touchées ?
4. Évaluer l'impact	Un administrateur du domaine s'y est-il connecté récemment ? La machine porte-t-elle une fonction de sécurité (annuaire, mises à jour, déploiement, EDR, sauvegarde, hyperviseur, bastion) ? Quelles activités métiers vitales dépendent d'elle ? Données personnelles, sensibles, réglementées ?
5. Évaluer l'urgence	Existe-t-il un mode dégradé pour les activités touchées ? L'activité malveillante est-elle récente et évolutive, ou ancienne et stable ? Y a-t-il un risque de généralisation imminente ?

Source

CERT-FR — Fiche réflexe « Compromission système — Qualification » (CERTFR-2024-RFX-005) : PDF. Pour un chiffrement en cours : CERTFR-2024-RFX-001 : PDF.

5.3 Endiguer : contenir l'attaque

L'endiguement regroupe les actions de début d'incident destinées à contenir l'ampleur de l'attaque et à redonner l'initiative aux défenseurs. Elles sont temporaires et doivent être cohérentes avec le périmètre qualifié.

Se connecter sans aggraver la situation

1. Agir à distance via l'**EDR** ou un outil de gestion à distance qui n'ouvre pas de session (type RMM).
2. Sinon, connexion **locale** (console physique, hors bande type iDRAC/iLO, console d'hyperviseur) avec un compte administrateur **local** à la machine.
3. En dernier recours, connexion réseau qui n'expose pas le mot de passe : PowerShell Remoting, WinRS, ou RDP en mode *Restricted Admin*.
4. Tracer chaque connexion dans la main courante.

Actions d'endiguement par priorité

Axe	Actions
Isoler	Isoler les machines compromises (quarantaine EDR, port de commutateur, VLAN de quarantaine) sans les éteindre ; bloquer au pare-feu, au proxy et au DNS les adresses et domaines de commande et contrôle identifiés ; si l'étendue est inconnue : couper l'accès Internet et les interconnexions (sites, partenaires, VPN).
Comptes	Désactiver les comptes utilisés par l'attaquant et révoquer leurs sessions et jetons ; changer depuis un poste sain les mots de passe des comptes compromis ; restreindre temporairement les comptes à privilèges au strict nécessaire. Coordonner ces actions pour ne pas alerter l'attaquant prématurément.
Préserver les biens essentiels	Déconnecter ou protéger les sauvegardes ; isoler les hyperviseurs et leur gestion ; protéger les contrôleurs de domaine ; activer les modes dégradés métier.
Surveiller	Renforcer la journalisation et la surveillance des zones saines pour détecter un rebond.

Fiche CERT-FR

Compromission système — Endiguement (CERTFR-2024-RFX-006) : PDF.

5.4 Cas particulier : chiffrement ou effacement en cours

1. **Couper la propagation** : déconnecter Internet, les liaisons inter-sites et les accès VPN ; isoler les segments réseau ; isoler en priorité les hyperviseurs et le stockage partagé.
2. **Mettre à l'abri les sauvegardes** : déconnecter les dépôts, suspendre les tâches de réplication/synchronisation qui propageraient des fichiers chiffrés, vérifier qu'une copie hors ligne existe.
3. **Arbitrer l'arrêt des machines** : l'isolement réseau est préférable à l'extinction (préservation de la mémoire). Si le chiffrement progresse et ne peut être arrêté autrement, la mise en pause (suspension) des machines virtuelles conserve la mémoire ; l'arrêt brutal reste un dernier recours, décidé en comparant la perte de données métier et la perte de preuves.
4. **Identifier le vecteur de déploiement** : GPO, tâches planifiées, outil de déploiement ou d'administration à distance détourné, comptes utilisés ; les neutraliser.
5. **Conserver la note de rançon** et un échantillon de fichiers chiffrés (pour identifier la famille et vérifier l'existence d'un déchiffreur sur nomoreransom.org).
6. **Ne pas payer**, ne pas négocier seul : se rapprocher des autorités, de l'assureur et du prestataire.

> **Fiche CERT-FR**
> Chiffrement ou effacement en cours — Endiguement (CERTFR-2024-RFX-002) : PDF. Guide ANSSI/Justice « Attaques par rançongiciels, tous concernés » : PDF.

5.5 Préserver les preuves

Collecter du plus volatil au moins volatil (principe de la RFC 3227) :

Ordre	Élément	Comment
1	Mémoire vive	Outil d'acquisition mémoire (Windows : WinPmem, Magnet RAM Capture ; Linux : AVML, LiME) ; pour une VM : instantané incluant la mémoire ou suspension.
2	État réseau et processus	Connexions actives, processus, sessions ouvertes (collecte automatisée de préférence).
3	Artefacts système	DFIR-ORC (ANSSI) sous Windows ; collecteurs d'artefacts sous Linux ; journaux d'événements, registre, tâches, services.
4	Disques	Copie bit à bit ou instantané de VM, empreinte (SHA-256) calculée et notée.
5	Journaux centraux	Exporter sans attendre ceux des pare-feu, proxy, VPN, DNS, EDR, messagerie, cloud : leur rétention peut être courte.

- Stocker les preuves hors du SI compromis, sur un support dédié ; noter qui a collecté quoi, quand, avec quel outil (chaîne de possession) : utile pour la plainte et l'assurance.
- Outils libres de l'ANSSI : DFIR-ORC (collecte Windows) et orc2timeline, ADTimeline (chronologie AD), DFIR-O365RC (Microsoft 365/Entra), DFIR4vSphere (VMware) — github.com/ANSSI-FR.

5.6 Investiguer : comprendre avant de reconstruire

L'investigation doit répondre à quelques questions structurantes, sans lesquelles la remédiation risque d'être incomplète :

1. **Point d'entrée** : par où et quand l'attaquant est-il entré (vulnérabilité, identifiants, hameçonnage, prestataire) ?
2. **Chronologie** : premières traces, latéralisation, élévation de privilèges, actions sur objectifs.
3. **Périmètre** : machines touchées, comptes compromis, niveau atteint (le Tier 0 est-il compromis ?).
4. **Persistance** : portes dérobées, comptes créés, tâches, services, clés SSH, applications OAuth, accès distants installés (outils de prise en main légitimes détournés).
5. **Exfiltration** : des données sont-elles sorties ? Lesquelles, combien, vers où ?

> **Référence**
> ANSSI — L'investigation et la qualification d'incidents (septembre 2026) : PDF.

5.7 Fiche de vérification : serveur Linux suspect

> **Avant de lancer ces commandes**
>
> Elles sont en lecture seule, mais toute connexion à une machine compromise laisse des traces et peut alerter l'attaquant. Collectez d'abord la mémoire et les artefacts si l'enjeu le justifie (5.5). Un rootkit peut falsifier les sorties : privilégiez des binaires de confiance (clé USB avec outils statiques) ou l'analyse de l'image disque depuis une autre machine.

```
vérifications Linux (lecture seule)

# Contexte
date -u; uptime; hostnamectl; uname -a

# Sessions et connexions
who -a; w
last -Faiw | head -50          # connexions récentes
lastb | head -30               # échecs (si disponible)
grep -E "Accepted|Failed|Invalid user" /var/log/auth.log* /var/log/secure* 2>/dev/null | tail -100

# Réseau
ss -tulpn                      # ports en écoute et processus
ss -tpn state established      # connexions établies

# Processus
ps auxfww
ls -l /proc/*/exe 2>/dev/null | grep -i deleted   # binaires supprimés encore en exécution
cat /etc/ld.so.preload 2>/dev/null                 # préchargement de bibliothèque (rootkit)

# Comptes et privilèges
awk -F: '$3==0 {print}' /etc/passwd                # comptes UID 0
getent group sudo wheel adm docker
ls -la /etc/sudoers.d/; grep -v '^#' /etc/sudoers | grep -v '^$'
for d in /root /home/*; do echo "== $d"; cat "$d/.ssh/authorized_keys" 2>/dev/null; done

# Persistance
for u in $(cut -d: -f1 /etc/passwd); do crontab -l -u "$u" 2>/dev/null | sed "s/^/[$u] /"; done
ls -la /etc/cron.* /var/spool/cron* 2>/dev/null
systemctl list-timers --all
systemctl list-unit-files --state=enabled
ls -lt /etc/systemd/system/ | head -30
cat /etc/rc.local 2>/dev/null; ls -la /etc/profile.d/

# Fichiers récemment modifiés et intégrité des paquets
find /etc /usr/bin /usr/sbin /usr/lib /tmp /var/tmp /dev/shm -xdev -type f -mtime -10 2>/dev/null
find / -xdev -type f -perm /6000 2>/dev/null       # setuid/setgid
debsums -c 2>/dev/null   ||   rpm -Va 2>/dev/null   # fichiers de paquets modifiés
```

5.8 Fiche de vérification : machine Windows suspecte

À exécuter de préférence via la fonction de réponse en direct de l'EDR, ou en PowerShell avec un compte administrateur local (jamais un administrateur du domaine). L'outil **Autoruns** (Microsoft Sysinternals) donne une vue complète des mécanismes de démarrage automatique.

```
vérifications Windows (PowerShell, lecture seule)

# Comptes et groupes locaux
Get-LocalUser | Select-Object Name,Enabled,LastLogon,PasswordLastSet
Get-LocalGroupMember -Group "Administrateurs"     # "Administrators" sur un système en anglais

# Connexions réseau et processus associés
Get-NetTCPConnection -State Established |
  Select-Object LocalAddress,LocalPort,RemoteAddress,RemotePort,OwningProcess,
    @{n='Process';e={(Get-Process -Id $_.OwningProcess -ErrorAction SilentlyContinue).Path}}

# Persistance : tâches, services, clés Run, WMI
Get-ScheduledTask | Where-Object State -ne 'Disabled' |
  Select-Object TaskPath,TaskName,@{n='Exec';e={$_.Actions.Execute + ' ' + $_.Actions.Arguments}}
Get-CimInstance Win32_Service | Where-Object { $_.PathName -notmatch 'C:\\Windows\\' } |
  Select-Object Name,State,StartMode,PathName
Get-ItemProperty 'HKLM:\Software\Microsoft\Windows\CurrentVersion\Run',
                 'HKCU:\Software\Microsoft\Windows\CurrentVersion\Run' -ErrorAction SilentlyContinue
Get-CimInstance Win32_StartupCommand | Select-Object Name,Command,Location,User
Get-CimInstance -Namespace root\subscription -ClassName __EventFilter
Get-CimInstance -Namespace root\subscription -ClassName CommandLineEventConsumer

# Événements clés
Get-WinEvent -FilterHashtable @{LogName='System';Id=7045} -MaxEvents 50     # services installés
Get-WinEvent -FilterHashtable @{LogName='Security';Id=4624} -MaxEvents 500 |
  Where-Object { $_.Properties[8].Value -eq 10 }                            # connexions RDP
Get-WinEvent -FilterHashtable @{LogName='Security';Id=1102} -ErrorAction SilentlyContinue  # journal effacé

# Détections Defender
Get-MpThreatDetection
```

5.9 Remédier : la méthode E3R de l'ANSSI

La remédiation vise à reprendre le contrôle du SI compromis et à rétablir un fonctionnement suffisant, sans laisser l'attaquant revenir. L'ANSSI la structure en trois étapes successives :

Étape	Objectif	Exemples d'actions
Endiguement	Contenir l'attaquant et limiter son action.	Isolement, coupures de flux, blocage des indicateurs, protection des sauvegardes (voir 5.3).
Éviction	Chasser l'intrus du cœur de confiance du SI.	Opération coordonnée, idéalement en un temps court : réinitialisation des secrets du Tier 0, suppression des persistances, fermeture du point d'entrée, durcissement d'urgence.
Éradication	Supprimer toutes ses emprises dans le reste du SI.	Assainissement ou reconstruction des serveurs et postes touchés, rotation de tous les secrets, surveillance renforcée pour détecter un retour.

Choisir son niveau d'ambition

Le volet stratégique de l'ANSSI propose de choisir explicitement entre plusieurs scénarios, du plus rapide au plus sûr : une remise en service au plus vite (rapide mais avec un risque de retour de l'attaquant élevé), une reprise de contrôle du cœur de confiance, ou une remédiation qui profite de la crise pour durcir le SI en profondeur. Ce choix appartient à la direction, éclairée par l'équipe technique : il doit être documenté.

Active Directory compromis : points de contrôle typiques

- ☐ Postes d'administration propres reconstruits depuis des supports de confiance ; nouveaux comptes d'administration créés depuis ces postes.
- ☐ Point d'entrée identifié et fermé (correctif, désactivation, coupure du flux).
- ☐ Mot de passe du compte **krbtgt** réinitialisé deux fois, en attendant entre les deux la réplication complète et au moins la durée de vie maximale des tickets (10 h par défaut).
- ☐ Mots de passe de tous les comptes à privilèges, comptes de service, mot de passe DSRM des contrôleurs de domaine et secrets des relations d'approbation réinitialisés.
- ☐ Persistances recherchées et supprimées : ACL AdminSDHolder, SIDHistory, attributs msDS-KeyCredentialLink, GPO modifiées, tâches et services sur les DC, délégations ajoutées.
- ☐ AD CS vérifié : modèles de certificats modifiés, certificats émis frauduleusement révoqués ; si la clé de l'autorité est compromise, reconstruction de la PKI.
- ☐ Si la compromission est profonde ou ancienne : reconstruction de la forêt envisagée plutôt qu'un nettoyage.
- ☐ Surveillance renforcée des événements d'authentification et de modification de l'annuaire pendant plusieurs semaines.

> **Corpus de référence**
> ANSSI — Cyberattaques et remédiation : les clés de décision (volet stratégique) ; piloter la remédiation (volet opérationnel) ; remédiation du Tier 0 Active Directory (volet technique) ; préparer la remédiation.

5.10 Reconstruire et reprendre l'activité

- Reconstruire depuis des **supports d'installation de confiance**, jamais depuis une image ou un modèle potentiellement compromis.
- Appliquer **tous les correctifs et le durcissement avant** de reconnecter au réseau.
- Restaurer les **données** (pas les systèmes) depuis des sauvegardes antérieures à l'intrusion, après analyse ; se méfier des sauvegardes postérieures au point d'entrée.
- Reconnecter **progressivement**, par ordre de priorité métier, sous surveillance renforcée.
- Changer **tous les secrets** : comptes, clés SSH, certificats, jetons d'API, mots de passe des équipements réseau, secrets des applications.
- Garder les accès Internet et partenaires restreints tant que l'éradication n'est pas confirmée.

5.11 Gestion de crise et communication

Cellule	Rôle
Stratégique (direction)	Décisions d'arbitrage : continuité, communication, juridique, financement, relation avec les autorités et l'assureur. Rythme : un point par demi-journée en phase aiguë.
Opérationnelle / technique	Conduite de l'investigation et de la remédiation, planification, remontée d'une synthèse claire et datée vers la cellule stratégique.
Métiers	Fonctionnement dégradé, priorités de redémarrage, besoins des clients.

- **Communication interne** rapide et factuelle : ce que l'on sait, ce que l'on ne sait pas, consignes (ne plus utiliser tel outil, ne pas communiquer à l'extérieur), prochain point.
- **Communication externe** préparée à l'avance (modèles en annexe D), cohérente avec les déclarations aux autorités ; ne jamais spéculer sur l'auteur ou minimiser ce que l'on ignore.
- Prévoir l'**épuisement des équipes** : rotations, repos, appui externe.
- Guides ANSSI : Crise cyber, les clés d'une gestion opérationnelle et stratégique ; Anticiper et gérer sa communication de crise cyber.

5.12 Scénarios fréquents : conduites à tenir

Scénario	Actions spécifiques
Compte de messagerie professionnel compromis	Révoquer toutes les sessions et jetons ; réinitialiser le mot de passe et les méthodes MFA ; supprimer les règles de transfert et de suppression ; vérifier les applications OAuth autorisées ; rechercher les courriels envoyés par l'attaquant (hameçonnage interne, fraude au virement) ; prévenir les correspondants concernés ; analyser les journaux d'audit (DFIR-O365RC pour Microsoft 365).
Site web compromis ou défiguré	Mettre le site en maintenance ; conserver une copie des fichiers, de la base et des journaux ; identifier la faille (extension, CMS non à jour, identifiants) ; réinstaller depuis une source saine et à jour ; changer tous les secrets (base, FTP/SFTP, comptes d'administration, clés d'API) ; vérifier l'absence de redirections malveillantes et de comptes ajoutés.
Serveur personnel ou VPS compromis	Couper l'exposition (pare-feu du fournisseur) ; prendre un instantané pour analyse ; considérer toutes les clés et mots de passe présents sur le serveur comme compromis ; reconstruire à neuf plutôt que nettoyer ; restaurer les données après vérification.
Vulnérabilité critique exploitée sur l'équipement d'accès distant	Appliquer le correctif ou la contre-mesure de l'éditeur ; rechercher les indicateurs de compromission publiés ; considérer les identifiants ayant transité par l'équipement comme compromis ; si traces trouvées : traiter comme une compromission système.
Poste infecté après ouverture d'une pièce jointe	Isoler via l'EDR ; identifier si l'utilisateur a des droits élevés ; rechercher le même courriel chez les autres destinataires et le supprimer ; bloquer les indicateurs ; réinitialiser le mot de passe de l'utilisateur depuis un poste sain ; réinstaller le poste.

5.13 Après l’incident : retour d’expérience

- Réunion de retour d’expérience sans recherche de coupable, dans les semaines qui suivent.
- Chronologie consolidée à partir de la main courante ; ce qui a fonctionné, ce qui a manqué.
- Plan d’action daté, avec responsables, et suivi en comité de direction.
- Mise à jour des procédures, de ce guide (annexes B et C) et du plan de continuité.

PARTIE 6

Plan de préparation

La qualité de la réponse se joue avant l'incident. Ce calendrier transforme les recommandations en routines simples, à adapter à la taille de votre structure.

6.1 Calendrier des routines de sécurité

Fréquence	Actions
Quotidien	Lire et traiter les alertes de l'EDR et de la supervision ; vérifier le succès des sauvegardes ; lire les alertes du CERT-FR.
Hebdomadaire	Appliquer les correctifs critiques ; revoir les connexions des comptes à privilèges et les accès distants inhabituels.
Mensuel	Cycle de correctifs ; scan de vulnérabilités ; revue des règles de pare-feu modifiées ; vérification de la surface exposée sur Internet.
Trimestriel	Test de restauration ; revue des comptes (départs, inactifs, prestataires) et des groupes à privilèges ; mise à jour des contacts d'urgence ; campagne de sensibilisation.
Annuel	Exercice de crise ; audit AD ; audit ou test d'intrusion externe ; revue de l'analyse de risques et de la PSSI ; mise à jour de ce guide ; vérification des contrats et de l'assurance.

6.2 Auto-évaluation rapide

Cochez honnêtement. Chaque case vide est une action pour votre feuille de route.

- ☐ Je dispose d'un inventaire à jour des équipements, logiciels et services exposés.
- ☐ La MFA protège tous les accès distants, la messagerie et les comptes à privilèges.
- ☐ Les comptes d'administration sont séparés et ne naviguent pas sur Internet.
- ☐ Les mots de passe administrateur locaux sont uniques (LAPS ou équivalent).
- ☐ Les équipements exposés à Internet sont corrigés en moins de 48 h en cas d'alerte.
- ☐ Aucun RDP, SMB, interface d'administration ou base de données n'est exposé sur Internet.
- ☐ Le réseau est segmenté ; les postes ne communiquent pas entre eux.
- ☐ Un EDR protège postes et serveurs, et ses alertes sont réellement traitées.
- ☐ Les journaux critiques sont centralisés, horodatés et conservés au moins 6 mois.
- ☐ Une sauvegarde hors ligne ou immuable existe ; une restauration a été testée ce trimestre.
- ☐ La console de sauvegarde ne dépend pas de l'AD de production et est protégée par MFA.
- ☐ La liste des services critiques et leur ordre de redémarrage sont écrits.
- ☐ La carte réflexe et les contacts d'urgence sont imprimés et accessibles hors SI.
- ☐ Un prestataire de réponse à incident et l'assureur sont identifiés, avec leurs contacts.
- ☐ Un exercice de crise a eu lieu dans les 12 derniers mois.
- ☐ Les utilisateurs savent comment signaler un message ou un comportement suspect.

6.3 Idée d'exercice sur table (2 heures)

1. **Scénario** : lundi 6 h, des utilisateurs signalent des fichiers renommés et une note de rançon ; la messagerie fonctionne encore ; l'hyperviseur principal ne répond plus.
2. **Questions** : qui est prévenu, comment, en combien de temps ? Qui décide de couper Internet ? Où est la main courante ? Les sauvegardes sont-elles intactes, comment le vérifier ? Que dit-on aux salariés à 8 h et aux clients à 10 h ? Quelles déclarations, sous quels délais ?
3. **Injects** : un journaliste appelle ; l'attaquant publie un échantillon de données ; le prestataire ne peut intervenir que demain.
4. **Débriefing** : trois améliorations concrètes, avec un responsable et une échéance.

> **Référence**
> ANSSI — Organiser un exercice de gestion de crise cyber : page du guide. Cybermalveillance.gouv.fr propose aussi un outil d'initiation à la gestion de crise.

COMPLÉMENTS

Annexes

Bibliothèque des références officielles, fiches à remplir et à imprimer, modèles de messages et glossaire.

Annexe A — Bibliothèque de référence (liens directs)

Documents gratuits, en français, publiés par les autorités compétentes. Les pages MesServicesCyber de l'ANSSI donnent toujours accès à la dernière version du guide.

ANSSI — sécuriser

Guide d'hygiène informatique — 42 mesures, le socle
https://messervices.cyber.gouv.fr/documents-guides/guide_hygiene_informatique_anssi.pdf

Mesures cyber préventives prioritaires — les 5 priorités
https://messervices.cyber.gouv.fr/documents-guides/20230503_anssi_mesures-cyber-preventives-prioritaires.pdf

Configuration d'un système GNU/Linux — durcissement Linux v2.0
https://messervices.cyber.gouv.fr/documents-guides/fr_np_linux_configuration-v2.0.pdf

Actionnable Linux (Ansible) — implémentation d'exemple
https://github.com/ANSSI-FR/actionnable-linux

Administration sécurisée des SI reposant sur AD — tiering, cloisonnement (2023)
https://messervices.cyber.gouv.fr/guides/recommandations-pour-ladministration-securisee-des-si-reposant-sur-ad

Administration sécurisée des SI — principes agnostiques
https://messervices.cyber.gouv.fr/guides/recommandations-relatives-ladministration-securisee-des-si

Authentification multifacteur et mots de passe —
https://messervices.cyber.gouv.fr/guides/recommandations-relatives-lauthentification-multifacteur-et-aux-mots-de-passe

Journalisation dans un environnement AD —
https://messervices.cyber.gouv.fr/guides/securiser-la-journalisation-dans-un-environnement-microsoft-active-directory

Architecture d'un système de journalisation —
https://messervices.cyber.gouv.fr/guides/recommandations-de-securite-pour-larchitecture-dun-systeme-de-journalisation

Mise en œuvre sécurisée d'un serveur Windows —
https://messervices.cyber.gouv.fr/guides/mise-en-oeuvre-securisee-dun-serveur-windows

Déploiement de conteneurs Docker —
https://messervices.cyber.gouv.fr/guides/recommandations-de-securite-relatives-au-deploiement-de-conteneurs-docker

Usage sécurisé d'(Open)SSH —
https://messervices.cyber.gouv.fr/guides/usage-securise-dopenssh

Recommandations relatives à TLS —
https://messervices.cyber.gouv.fr/guides/recommandations-de-securite-relatives-tls

Sauvegarde des SI (fondamentaux) —
https://messervices.cyber.gouv.fr/guides/fondamentaux-sauvegarde-systemes-dinformation

Sécurisation d'une infrastructure VMware —
https://messervices.cyber.gouv.fr/guides/securisation-dune-infrastructure-vmware

Catalogue complet des guides — plus d'une centaine de guides
https://messervices.cyber.gouv.fr/catalogue

Réagir : CERT-FR et ANSSI

Fiche réflexe — Compromission système — Qualification —
https://cert.ssi.gouv.fr/uploads/CERTFR-2024-RFX-005-2.pdf

Fiche réflexe — Compromission système — Endiguement —
https://cert.ssi.gouv.fr/uploads/CERTFR-2024-RFX-006-2.pdf

Fiche réflexe — Chiffrement/effacement en cours — Qualification —
https://cert.ssi.gouv.fr/uploads/CERTFR-2024-RFX-001-1.pdf

Fiche réflexe — Chiffrement/effacement en cours — Endiguement —
https://cert.ssi.gouv.fr/uploads/CERTFR-2024-RFX-002-2.pdf

L'investigation et la qualification d'incidents — 2026
https://messervices.cyber.gouv.fr/documents-guides/ANSSI_investigation_qualification_incidents_cles_de_decision.pdf

Cyberattaques et remédiation — les clés de décision — volet stratégique
https://messervices.cyber.gouv.fr/guides/cyberattaques-et-remediation-les-cles-de-decision

Piloter la remédiation — volet opérationnel
https://messervices.cyber.gouv.fr/documents-guides/20231218_Volet_operationnel_cyberattaquesetremediation_a5_v1j.pdf

La remédiation du Tier 0 Active Directory — volet technique
https://messervices.cyber.gouv.fr/documents-guides/20231218_Volet_technique_cyberattaquesetremediation_a5_v1h.pdf

Crise cyber, les clés d'une gestion opérationnelle et stratégique —
https://messervices.cyber.gouv.fr/guides/crise-cyber-les-cles-dune-gestion-operationnelle-et-strategique

Attaques par rançongiciels, tous concernés — ANSSI et ministère de la Justice
https://messervices.cyber.gouv.fr/documents-guides/anssi-guide-attaques_par_rancongiciels_tous_concernes-v1.0.pdf

Outils DFIR de l'ANSSI — DFIR-ORC, ADTimeline, DFIR-O365RC, DFIR4vSphere, ORADAD
https://github.com/ANSSI-FR

CNIL et Cybermalveillance.gouv.fr

Guide de la sécurité des données personnelles — 25 fiches
https://www.cnil.fr/sites/default/files/2026-05/cnil_guide_securite_personnelle.pdf

Plaquette Cybersécurité 2026 (CNIL) —
https://www.cnil.fr/sites/default/files/2026-05/plaquette_cybersecurite_2026_0.pdf

Notifier une violation de données — 72 h
https://www.cnil.fr/fr/notifier-une-violation-de-donnees-personnelles

Guide RGPD de l'équipe de développement —
https://github.com/LINCnil/Guide-RGPD-du-developpeur

Fiche réflexe rançongiciels — professionnels —
https://www.cybermalveillance.gouv.fr/medias/2025/06/260204_FicheReflexe_Rancongiciels_Pro_SCREEN.pdf

Les essentiels de votre sécurité numérique —
https://www.cybermalveillance.gouv.fr/medias/2023/11/231003_Fiche_A4_Conseils_SCREEN.pdf

Assistance aux victimes —
https://www.cybermalveillance.gouv.fr/17cyber

Autorités francophones

CCB (Belgique) — Premiers secours en cas de cyberincident —
https://ccb.belgium.be/fr/open-media/1264/download

CCB (Belgique) — Guide de gestion des incidents —
https://ccb.belgium.be/sites/default/files/cybersecurity-incident-management-guide-FR.pdf

CCB (Belgique) — CyberFundamentals — référentiel par niveaux
https://atwork.safeonweb.be/fr/tools-resources/cyberfundamentals-framework

Suisse — Norme minimale TIC 2023 — 106 mesures
https://www.bwl.admin.ch/dam/bwl/fr/dokumente/themen/ikt/ikt-minimalstandard-2023.pdf.download.pdf/Norme%20minimale%20TIC%20-%202023.pdf

Suisse (OFCS) — Méthode MCSR 2025 —
https://www.ncsc.admin.ch/dam/ncsc/de/dokumente/dokumentation/methode/Methode-CSRM-2025-FR.pdf.download.pdf/Methode-CSRM-2025-FR.pdf

Canada — Guide sur les rançongiciels ITSM.00.099 —
https://www.cyber.gc.ca/sites/default/files/itsm00099-guide-rancongiciels-f.pdf

Canada — Contrôles de cybersécurité de base (PME) —
https://cyber.gc.ca/fr/orientation/controles-de-cybersecurite-de-base-pour-les-petites-et-moyennes-organisations

Communautés professionnelles

InterCERT France — communauté des CERT/CSIRT français, origine des fiches réflexes
https://www.intercert-france.fr/

CLUSIF — méthode MEHARI, panorama de la cybercriminalité
https://clusif.fr/

Annexe B — Contacts d'urgence (à remplir et imprimer)

Rôle	Nom et téléphone	Autre moyen (mobile perso, e-mail hors SI)
Décideur / direction		
Suppléant direction		
Pilote incident (RSSI / DSI)		
Suppléant technique		
Prestataire de réponse à incident		
Infogérant / support		
Hébergeur / cloud		
Opérateur télécom / Internet		
Éditeur EDR / SOC		
Assureur cyber (n° de contrat)		
Avocat / juridique		
Communication		
DPO		
CSIRT régional		
CERT-FR	3218 / 09 70 83 32 18	cert-fr@ssi.gouv.fr
Gendarmerie / police locale		

Comptes « bris de glace », codes de récupération et clés de déchiffrement des sauvegardes : conservés à l'endroit suivant (coffre, enveloppe scellée) : _____

Annexe C — Main courante d'incident (modèle)

Une ligne par action ou événement. Ne jamais la stocker sur le SI compromis.

Date / heure (fuseau)	Qui	Action ou événement	Machines / comptes	Résultat

Annexe D — Modèles de messages de crise

Message interne (premières heures)

> « Notre système informatique fait actuellement l'objet d'un incident de sécurité. Par précaution, [outils concernés] sont suspendus. Merci de **ne pas allumer / ne pas reconnecter** [équipements], de **ne pas utiliser** la messagerie professionnelle jusqu'à nouvel ordre et de **ne faire aucune déclaration à l'extérieur**. Les équipes et nos partenaires sont mobilisés. Prochain point d'information : [heure], par [canal]. Contact : [nom, téléphone]. »

Message aux clients et partenaires

> « [Organisation] a détecté le [date] un incident de cybersécurité affectant une partie de ses systèmes. Des mesures de protection ont été prises immédiatement et nous sommes accompagnés par des spécialistes. Les autorités compétentes ont été informées. À ce stade, [ce qui est connu / les services concernés]. Par prudence, nous vous recommandons de vous méfier de tout message inhabituel semblant provenir de nous, en particulier toute demande de paiement ou de changement de coordonnées bancaires. Nous vous tiendrons informés le [date]. Contact dédié : [coordonnées]. »

Principes

- Factuel, daté, sans spéculation sur l'auteur ni sur l'ampleur non vérifiée.
- Cohérent avec les déclarations faites aux autorités et à l'assureur.
- Validé par la direction (et le juridique) avant diffusion ; diffusé par un canal non compromis.

Annexe E — Glossaire

Terme	Définition
AD / Tier 0	Active Directory, annuaire Microsoft. Le Tier 0 regroupe tout ce qui contrôle l'annuaire : sa compromission donne la maîtrise totale du SI.
CERT / CSIRT	Équipe de réponse aux incidents de sécurité informatique.
EDR	Outil de détection et de réponse sur les postes et serveurs (au-delà de l'antivirus).
Endiguement	Actions de début d'incident visant à contenir l'attaque ; temporaires.
E3R	Démarche de remédiation de l'ANSSI : endiguement, éviction, éradication.
IOC	Indicateur de compromission : adresse, domaine, empreinte de fichier, trace caractéristique.
LAPS	Solution Microsoft de mots de passe administrateur locaux uniques et renouvelés.
Main courante	Journal chronologique des actions et événements d'un incident.
MFA	Authentification multifacteur : au moins deux facteurs (savoir, posséder, être).
PRIS	Prestataire qualifié par l'ANSSI pour la réponse aux incidents de sécurité.
Qualification	Confirmation d'un incident et évaluation de sa gravité (périmètre, impact, urgence).
Remédiation	Reprise de contrôle d'un SI compromis et retour à un fonctionnement suffisant.

Terme	Définition
RPO / RTO	Perte de données maximale admissible / durée d'interruption maximale admissible.
SIEM / SOC	Outil de corrélation des journaux / centre opérationnel de sécurité qui surveille les alertes.
TLP:CLEAR	Information diffusable sans restriction.